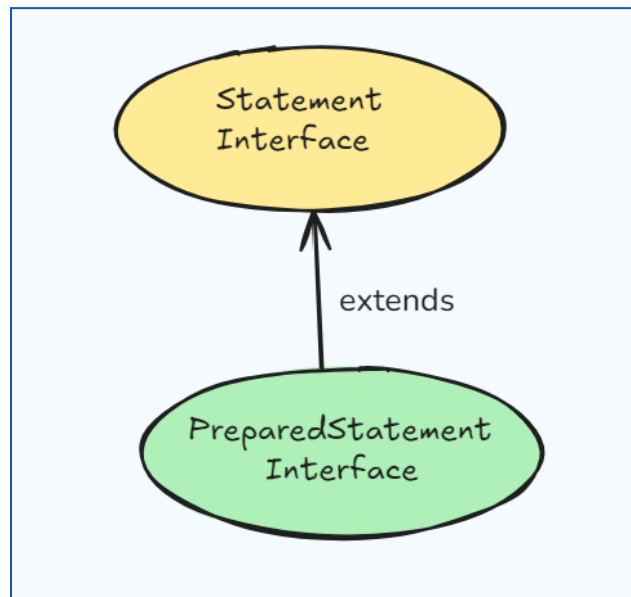


16 - Statement VS PreparedStatement

Statement and PreparedStatement are two interfaces in Java used to execute SQL queries in a database.

- **Statement** : Parent interface for executing SQL queries.
- **PreparedStatement** : Child interface of Statement, offering more features and security.



👉 **Difference between a Statement and Prepared Statement:**

Feature	Statement	Prepared Statement
SQL Query Structure	SQL query with data is passed directly as a string.	SQL query uses placeholders (?) for parameters.
Parameterization	No parameterization; data must be embedded in the query.	Supports parameterized queries with placeholders.
Creation Method	Created using the <code>createStatement()</code> method of the connection object.	Created using the <code>prepareStatement()</code> method of the connection object.

SQL Query Requirement	No SQL query is passed when creating the Statement object. The query is passed at the time of execution.	SQL query must be passed at the time of creating the PreparedStatement object.
Security	Vulnerable to SQL injection attacks.	Safe from SQL injection due to parameterization.
Reusability	The same Statement object can be reused to execute different queries.	A new PreparedStatement object is needed for each unique SQL query.
Compilation	SQL query is compiled every time it's executed.	Query is precompiled and can be executed multiple times with different parameters, improving performance.
Efficiency	Less efficient for repeated queries, as each query is parsed and compiled separately.	More efficient for repeated execution, as the query is compiled only once.
Method for Setting Data	Data is embedded in the SQL query string.	Data is set using set methods (setString(), setInt(), etc.) for the placeholders.

Examples	
Statement	<pre>String query = "INSERT INTO users (id, name) VALUES (1, 'John')"; Statement stmt = conn.createStatement();</pre>

	<pre>stmt.executeUpdate(query);</pre>
PreparedStatement	<pre>String query = "INSERT INTO users (id, name) VALUES (?, ?)"; PreparedStatement pstmt = conn.prepareStatement(query); pstmt.setInt(1, 1); pstmt.setString(2, "Muskan"); pstmt.executeUpdate();</pre>